MindVault Security Policy: Enterprise Zero-Trust and Identity Governance
Document Identifier: MV-DOC-02 | Version: 3.1 | Classification: Security Directive
==========

Section 1: Authentication Gateway and Token Lifecycle
Authentication filter executes prior to rate limiter. Missing Bearer token results in immediate 401 Unauthorized. User access JWT tokens have a strict time-to-live (TTL) of 15 minutes. Refresh tokens rotate every 7 days. Session authentication utilizes write-through caching; Redis failure triggers failover to PostgreSQL session backup t

Section 2: Horizontal Multi-Tenant Isolation
Horizontal tenant isolation is cryptographically guaranteed by scoping every database predicate to the verified workspaceId extracted from the signed token. RBAC links User via WorkspaceRole to Workspace, gating al child Document and DocumentChunk records. Users cannot query assets belonging to foreign workspaces.

Section 3: Rate Limiting Boundaries and Governance
API rate limiting tiers: Free tier permits up to 100 req/min; Enterprise tier allows up to 1000 req/min before returning HTTP 429 Too Many Requests.

Section 4: Role Hierarchy and Cryptographic Authority
Workspace Admin is scoped strictly to tenant assets including document uploads, user invites, and API keys. Platform Superadmin oversees physical infrastructure and cluster nodes. Tenant encryption key rotation requires Security Incident Officer role; Tier-1 on-call personnel do not possess key rotation authority.